

10주차 1차시

정보 보안(1)

선택이 아닌 필수_정보 보안 기술과 정보 윤리

1 정보 보안의 개요

2 악성코드

3 해킹



정보 보안(1)

◆ 학습목표

- 정보 보안의 목표, 정보 보안을 위협하는 공격 형태, 정보 보안 서비스에 대해 공부한다.
- 악성코드의 개념과 종류를 공부한다.
- 해킹의 개념과 종류를 공부한다.

1. 정보 보안의 개요

◆ 2011년 농협 전산망 해킹 사고



1. 정보 보안의 개요

1) 정보 보안의 개념과 목표

◆ 정보 보안의 개념

- 정보를 수집하여 가공하고 저장한 후 송수신하는 과정에서 발생하는 정보의 불법 훼손 및 변조, 유출 등을 방지하기 위한 관리적, 기술적 방법

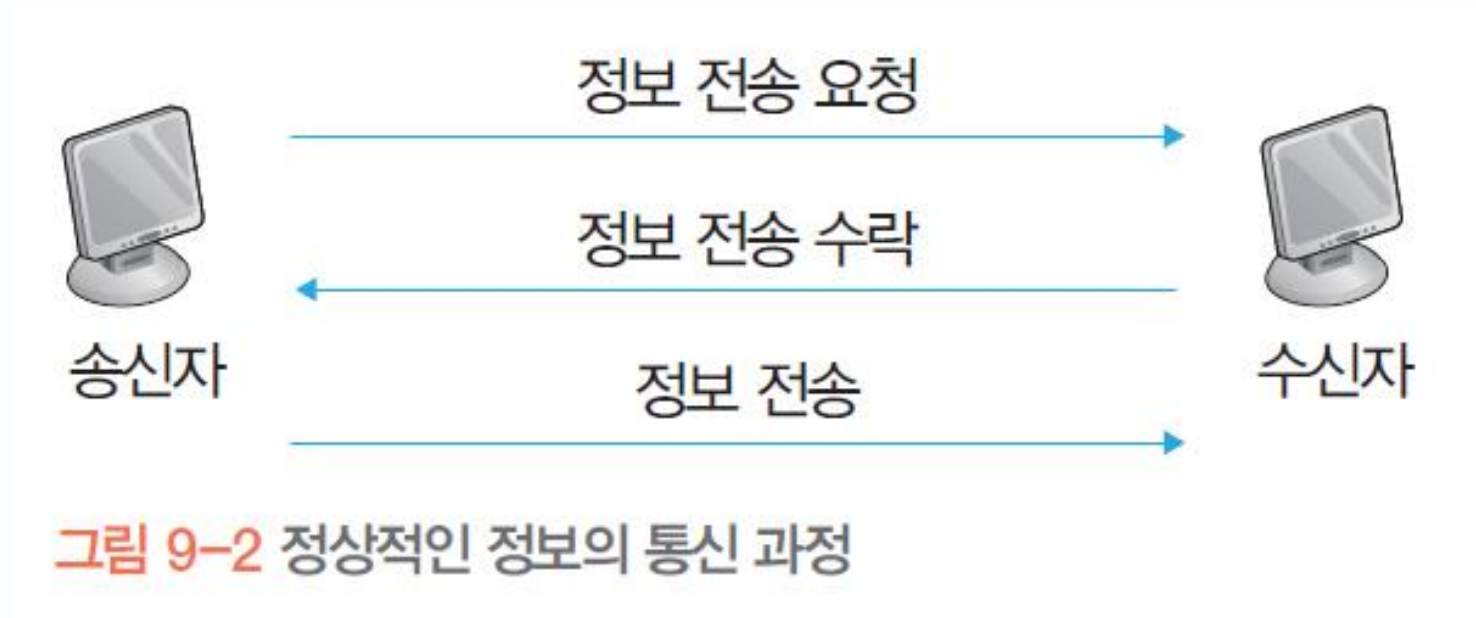
◆ 정보 보안의 목표

- 기밀성 : 허가되지 않은 사용자 또는 객체가 해당 정보의 내용을 알 수 없도록 비밀을 보장하는 것
- 무결성 : 허가되지 않은 사용자 또는 객체가 정보를 함부로 수정할 수 없게 하는 것
- 가용성 : 허가된 사용자 또는 객체가 정보에 접근하면 언제든지 사용할 수 있게 하는 것

1. 정보 보안의 개요

2) 정보 보안을 위협하는 공격 형태

◆ 정상적인 정보의 통신 과정



◆ 정보 보안을 위협하는 공격 형태

- 정보 가로막기
- 정보 가로채기
- 정보 수정
- 정보 위조

1. 정보 보안의 개요

2) 정보 보안을 위협하는 공격 형태

◆ 정보 가로막기

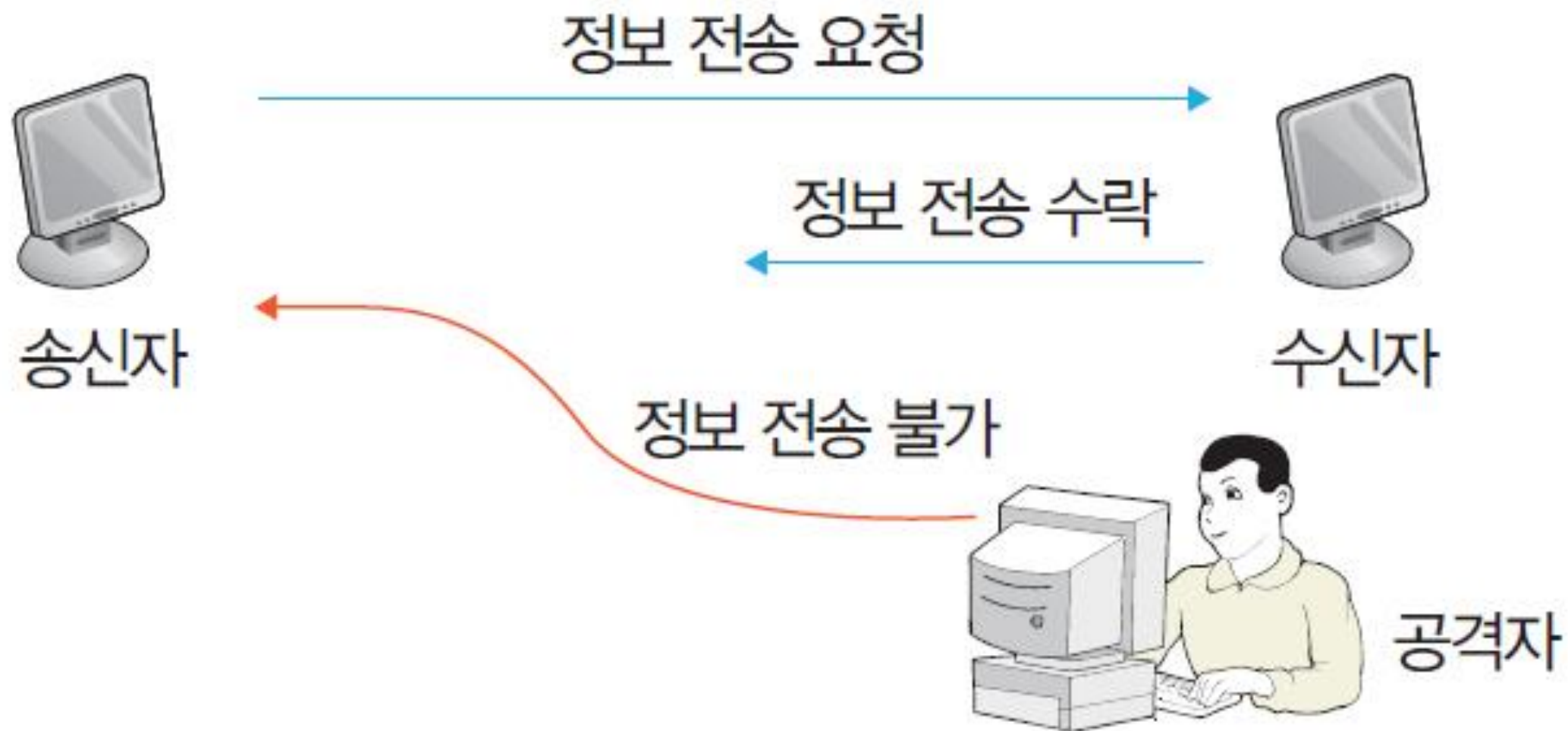


그림 9-3 정보 가로막기

1. 정보 보안의 개요

2) 정보 보안을 위협하는 공격 형태

◆ 정보 가로채기

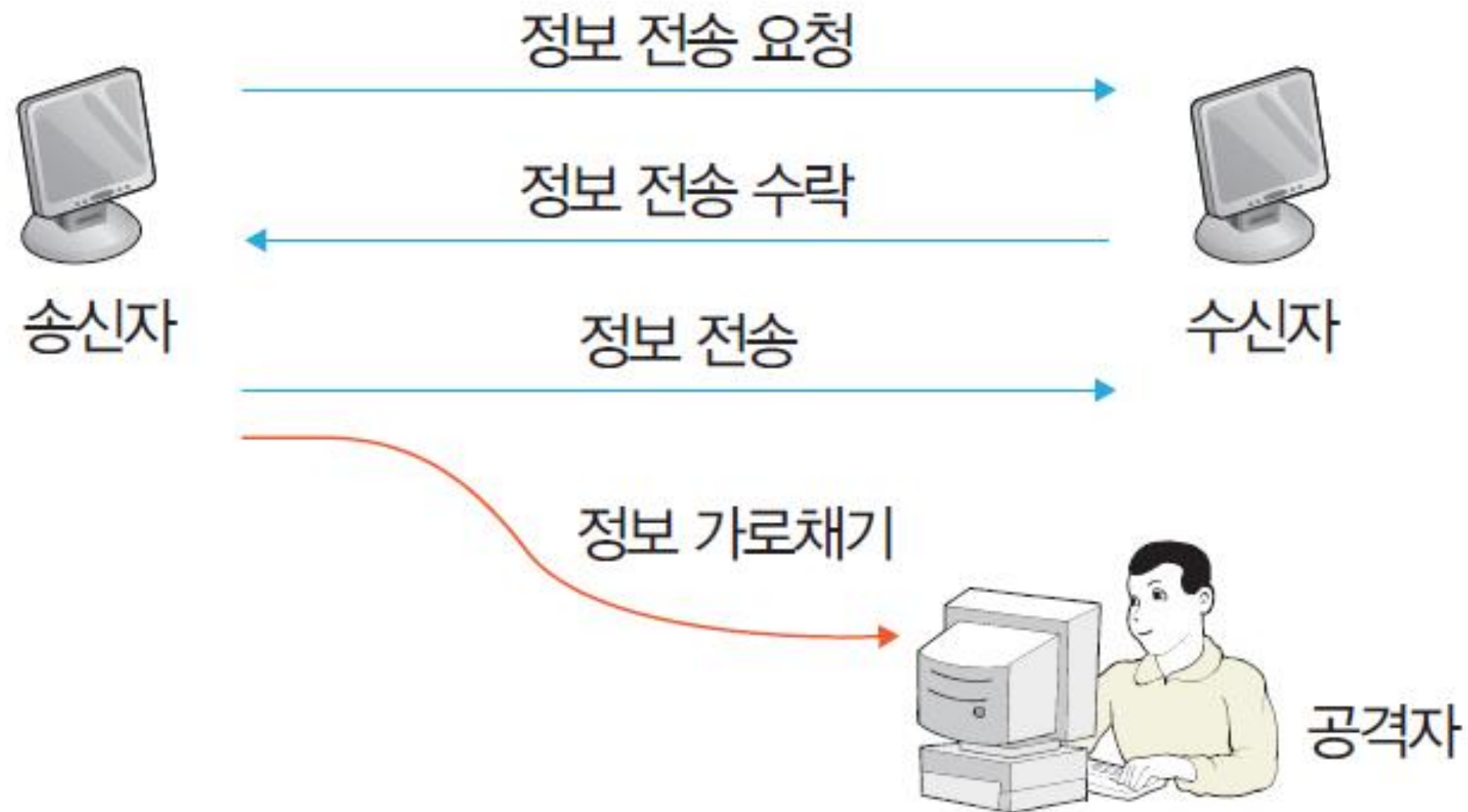


그림 9-4 정보 가로채기

1. 정보 보안의 개요

2) 정보 보안을 위협하는 공격 형태

◆ 정보 수정

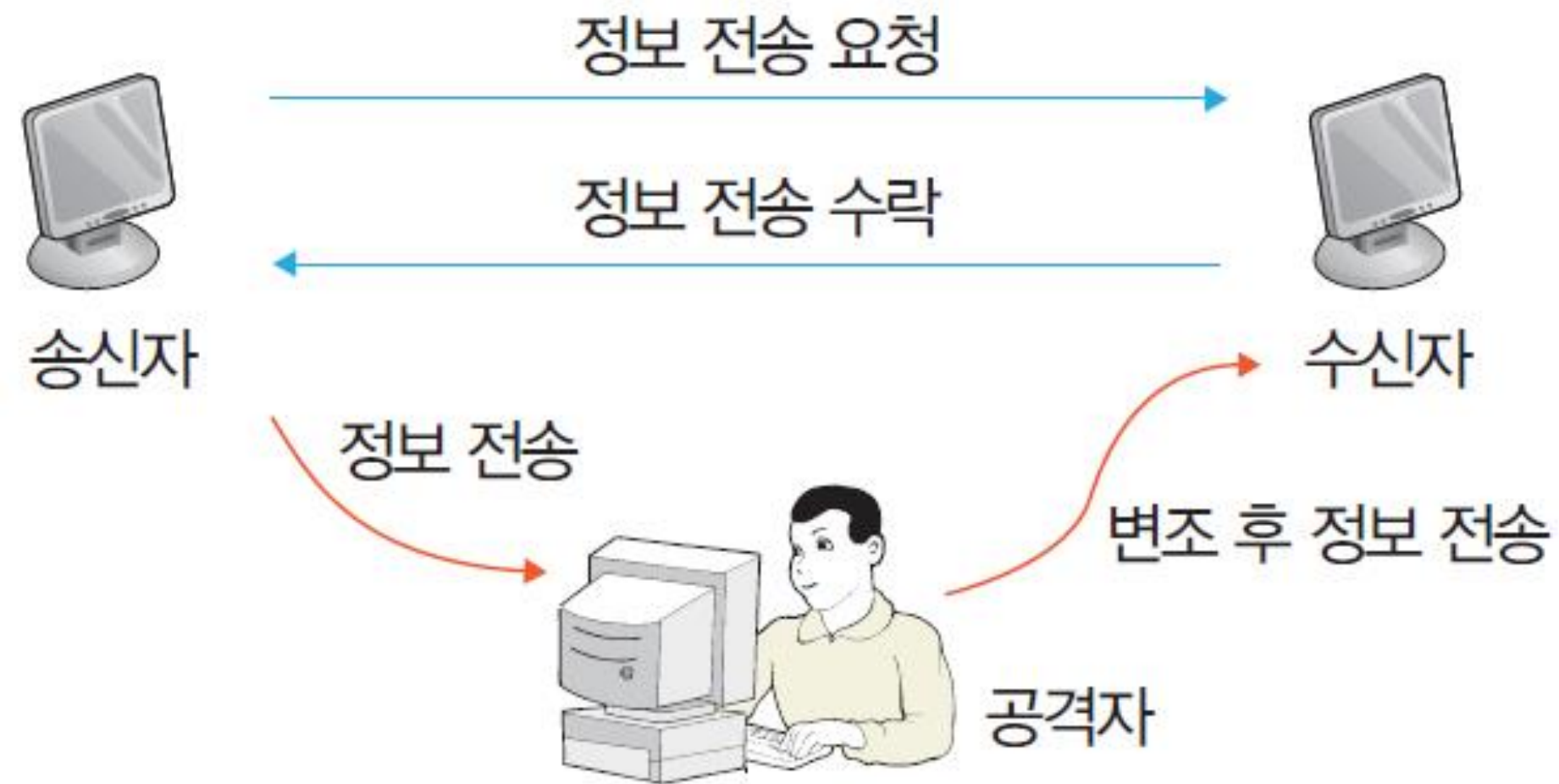
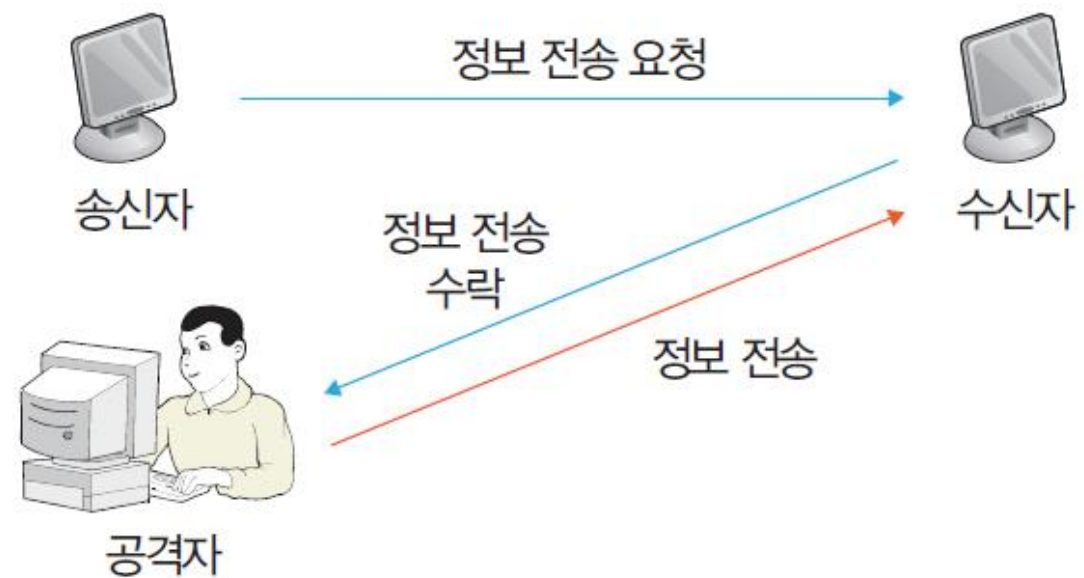


그림 9-5 정보 수정

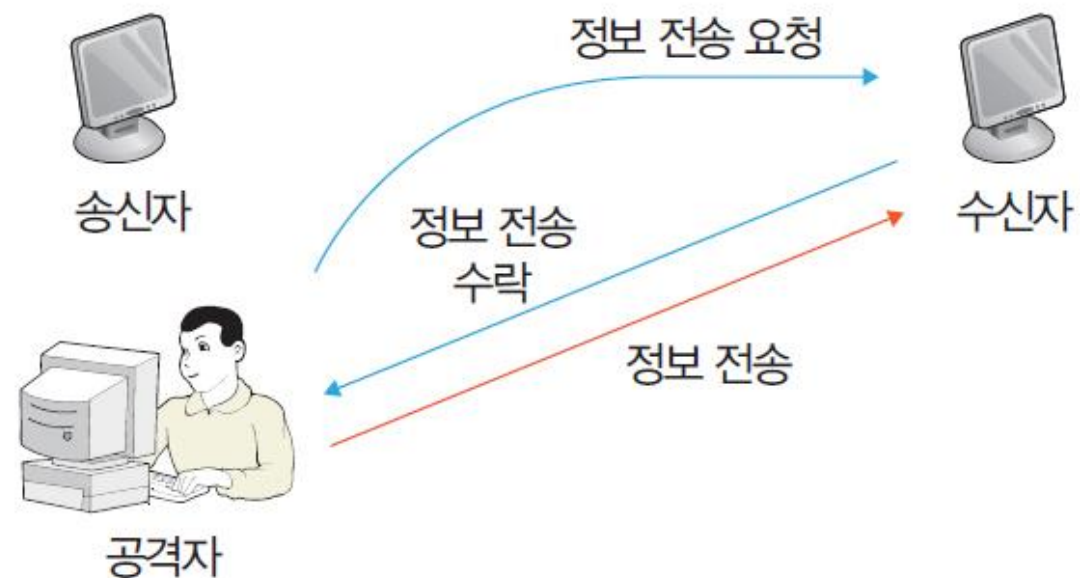
1. 정보 보안의 개요

2) 정보 보안을 위협하는 공격 형태

◆ 정보 위조



(a) 송신자가 정보 전송 요청을 하는 경우



(b) 공격자가 정보 전송 요청을 하는 경우

그림 9-6 정보 위조

1. 정보 보안의 개요

3) 정보 보안을 위한 서비스

◆ 인증

- 정보시스템에서 송신자 및 수신자의 신분을 확인하는 서비스

◆ 접근 제어

- 허가되지 않은 사용자가 정보에 접근할 수 없도록 막는 서비스

◆ 부인 방지

- 송신자 또는 수신자가 정보를 송신 또는 수신한 후 그 사실에 대해 부인하지 못하도록 하는 서비스

2. 악성 코드

1) 악성코드의 개념과 종류

◆ 개념

- 컴퓨터에 악영향을 끼칠 수 있는 모든 소프트웨어
- 웹 페이지를 검색하거나 P2P 서비스를 이용하거나 셰어웨어를 사용하거나 불법 복제 프로그램을 사용하거나 전자메일에 첨부된 파일을 열 때 침투
- 주요 증상으로는 네트워크 트래픽 발생, 시스템 성능 저하, 파일 삭제, 전자메일 자동 발송, 개인 정보 유출 등이 있음

◆ 종류

- 컴퓨터 바이러스
- 웜
- 트로이 목마

2. 악성 코드

2) 컴퓨터 바이러스

◆ 개념

- 사용자 컴퓨터 내부에 있는 프로그램이나 실행 가능한 데이터에 자신 또는 변형된 자신을 복사하는 명령어들의 조합

◆ 감염 경로

- 불법 복제한 CD를 사용하거나 여러 사람이 공동으로 사용하는 컴퓨터에서 작업한 USB를 통해 감염
- 인터넷으로 자료를 주고받을 때 감염되기도 함

2. 악성 코드

2) 컴퓨터 바이러스

◆ 주요 증상

- 컴퓨터가 구동되지 않거나 구동되더라도 평소보다 시간이 오래 걸림
- 자동으로 하드디스크가 포맷됨
- 특정 프로그램이 실행되지 않거나 실행되더라도 평소보다 오래 걸림
- 메모리나 하드디스크 용량이 줄어듦
- 파일이 열리지 않거나 파일 이름이나 크기가 변경됨
- 컴퓨터 화면에 이상한 글자가 나타나거나 프로그램의 크기가 달라짐

2. 악성 코드

2) 컴퓨터 바이러스

표 9-1 바이러스의 분류

분류	특징	종류
제1세대 원시형 바이러스 (primitive virus)	· 도스나 윈도우 초기 버전에서 출현한 대부분의 바이러스를 칭한다. · 구조가 단순해 분석하기 쉽다.	미켈란젤로 바이러스, 브레인 바이러스, 돌 바이러스(stoned virus), LBC 바이러스, 예루살렘 바이러스(Jerusalem virus), CIH 바이러스
제2세대 암호화 바이러스 (encryption virus)	· 백신이 등장하면서부터 출현했다. · 백신이 바이러스를 진단할 수 없도록 바이러스가 암호화되어 저장되어 있다.	폭포 바이러스(cascade virus), 느림보 바이러스(slow virus)
제3세대 은폐형 바이러스 (stealth virus)	· 컴퓨터를 감염시킨 후에도 메모리 손실이나 파일 크기의 변화가 없는 것처럼 은폐한다. · 기억 장소에 기생하면서 감염된 파일의 길이가 늘어나지 않은 것처럼 보이게 한다. · 백신 프로그램이 치료하려고 해도 감염되기 전의 내용을 보여줌으로써 바이러스가 없는 것처럼 속인다.	브레인 바이러스(brain virus), 조시 바이러스(Joshi virus), 방랑자.1347 바이러스(Wanderer.1347 virus), 프로도 바이러스(Frodo virus)
제4세대 갑옷형 바이러스 (armor virus)	· 암호를 푸는 부분을 감염시켜 실행할 때마다 자기 변형을 시도하기 때문에 사용자나 백신 프로그램이 감염 사실을 알지 못하게 한다.	고래 바이러스(whale virus), 다형성 바이러스(polymorphic virus)
제5세대 매크로 바이러스 (macro virus)	· 아래아한글이나 MS 오피스 같은 응용 프로그램의 매크로 내부에서 기생하여 동작한다.	엑셀 매크로 바이러스(ExcelMacro virus)
제6세대 차세대 바이러스 (next generation virus)	· 개인 정보의 유출 및 도용이나 시스템의 파괴 및 장악 등 사이버 범죄에 사용되어 심각한 피해를 줄 수 있는 바이러스를 모두 말한다.	-

2. 악성 코드

3) 웜

◆ 개념

- 독립적으로 자기 복제를 실행해 번식하는 컴퓨터 프로그램 또는 실행 가능한 코드

◆ 감염 경로

- 네트워크를 통해 스스로 감염됨
- 보통 전자메일에 첨부되어 상대방 컴퓨터에 전송됨

2. 악성 코드

3) 웜

◆ 증상

- 컴퓨터 시스템에 무리를 줌
- 특정 파일을 0바이트로 만듦
- 하드디스크 포맷
- 인터넷 속도가 느려짐
- 사용자의 정보를 빼냄

2. 악성 코드

4) 트로이 목마

◆ 개념

- 정상적인 프로그램으로 가장하여 숨어 있다가 프로그램이 실행될 때 활성화되어 자료 삭제, 정보 탈취 등 의도하지 않은 기능을 수행하는 프로그램 또는 실행 가능한 코드



영화 'Troy' 에 등장하는 트로이 목마

2. 악성 코드

4) 트로이 목마

◆ 감염 경로

- 전자메일이나 소프트웨어에 숨어 있다가 인터넷을 통해 특정 컴퓨터가 감염되면, 해커가 감염된 컴퓨터의 정보를 탈취



2. 악성 코드

4) 트로이 목마

◆ 증상

- 해커가 악의적인 목적으로 컴퓨터의 자료를 빼내갈 수 있음
- 예를 들어 사용자가 누른 자판 정보를 외부에 알려주기 때문에 신용카드 번호나 비밀번호 등이 유출될 수 있음

2. 악성 코드

5) 기타 유해 프로그램

◆ 개념

- 컴퓨터 바이러스처럼 악의적인 목적으로 사용자에게 피해를 주는 것은 아니지만, 컴퓨터 이용에 불편을 주거나 다른 악성코드에 의해 악용될 수 있는 프로그램

◆ 스파이웨어(spyware)

- 사용자의 동의 없이 설치되어 광고나 마케팅용 정보를 수집하거나 개인 정보를 몰래 훔쳐가는 프로그램

◆ 키로거(key logger)

- 키보드로부터 정보를 수집하여 저장하고, 필요한 경우 특정 전자메일로 저장된 정보를 전송하는 프로그램

◆ 조크(joke)

- 악의적인 목적 없이 사용자의 심적 동요나 불안을 조장하는 가짜 컴퓨터 바이러스

3. 해킹

1) 해킹

◆ 개념

- 다른 사람의 컴퓨터 또는 정보시스템에 침입하여 정보를 빼내는 행위

◆ 종류

- 도스
- 디도스
- 스푸핑
- 스니핑
- XSS
- 피싱



3. 해킹

2) 도스

◆ 도스

- Denial of Service의 약자로 '서비스 거부 공격'이라고도 함
- 공격자가 좀비 컴퓨터를 이용하여 공격 대상 컴퓨터나 네트워크에 과도한 데이터를 보내 시스템의 성능을 급격히 저하시킴



그림 9-9 도스의 동작

3. 해킹

3) 디도스

◆ 디도스

- Distributed Denial of Service의 약자로 '분산 서비스 거부' 또는 '분산 서비스 거부 공격'이라고 함
- 공격자는 여러 대의 좀비 컴퓨터를 분산 배치하여 동시에 공격 대상 컴퓨터나 네트워크를 공격

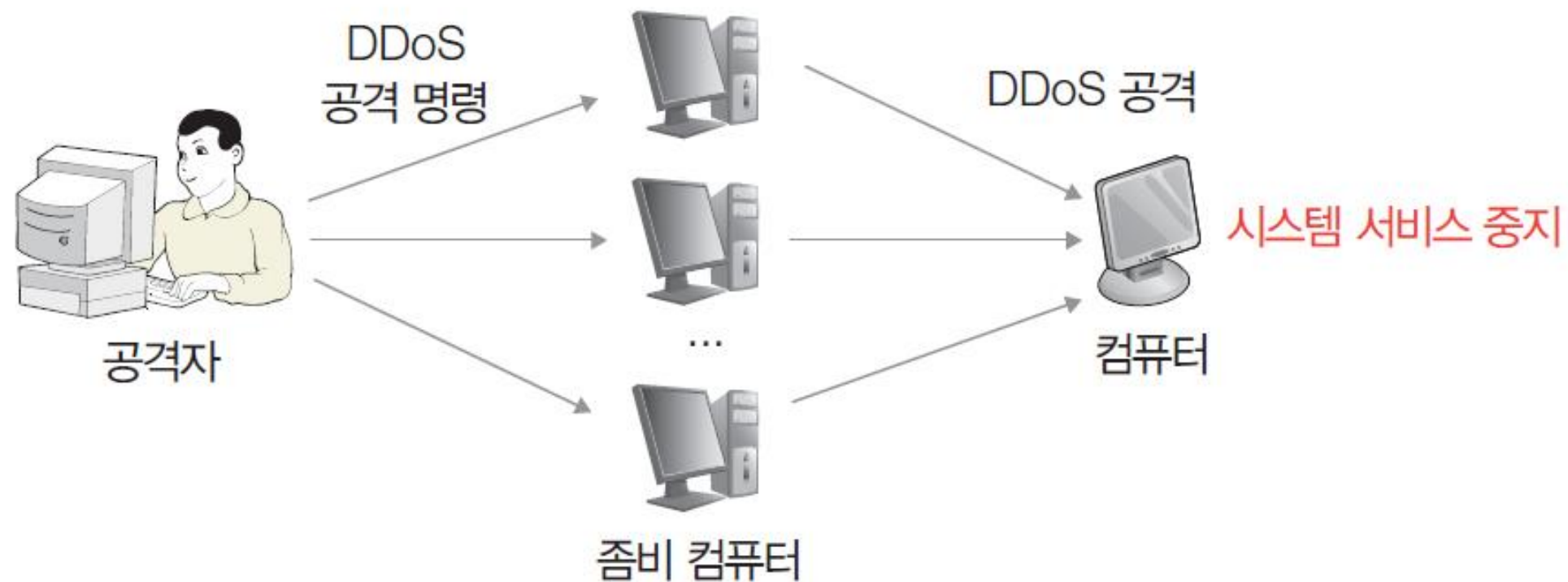


그림 9-10 디도스의 동작

3. 해킹

4) 스푸핑

◆ 스푸핑

- 공격자가 MAC 주소, IP 주소, 전자메일 주소 등 자신의 정보를 위장하여 정상적인 사용자나 시스템이 위장된 가짜 사이트를 방문하도록 유도한 뒤 정보를 빼가는 수법

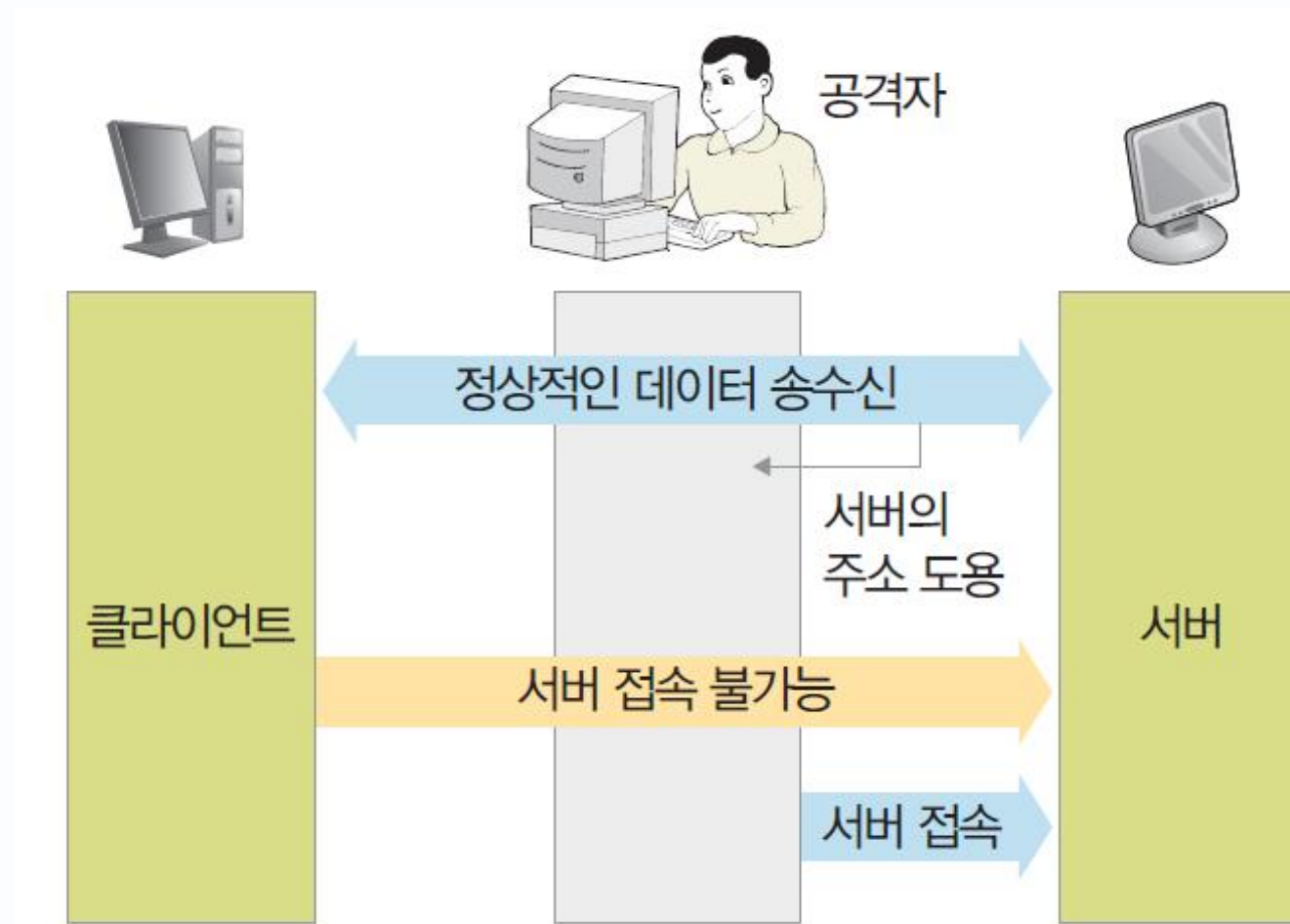


그림 9-11 IP 스푸핑의 동작

3. 해킹

5) 스니핑

◆ 스니핑

- 네트워크에서 주고받는 데이터를 도청하여 사용자의 ID, 비밀번호, 전자메일 내용, 쿠키(cookie) 등을 가로채는 수법

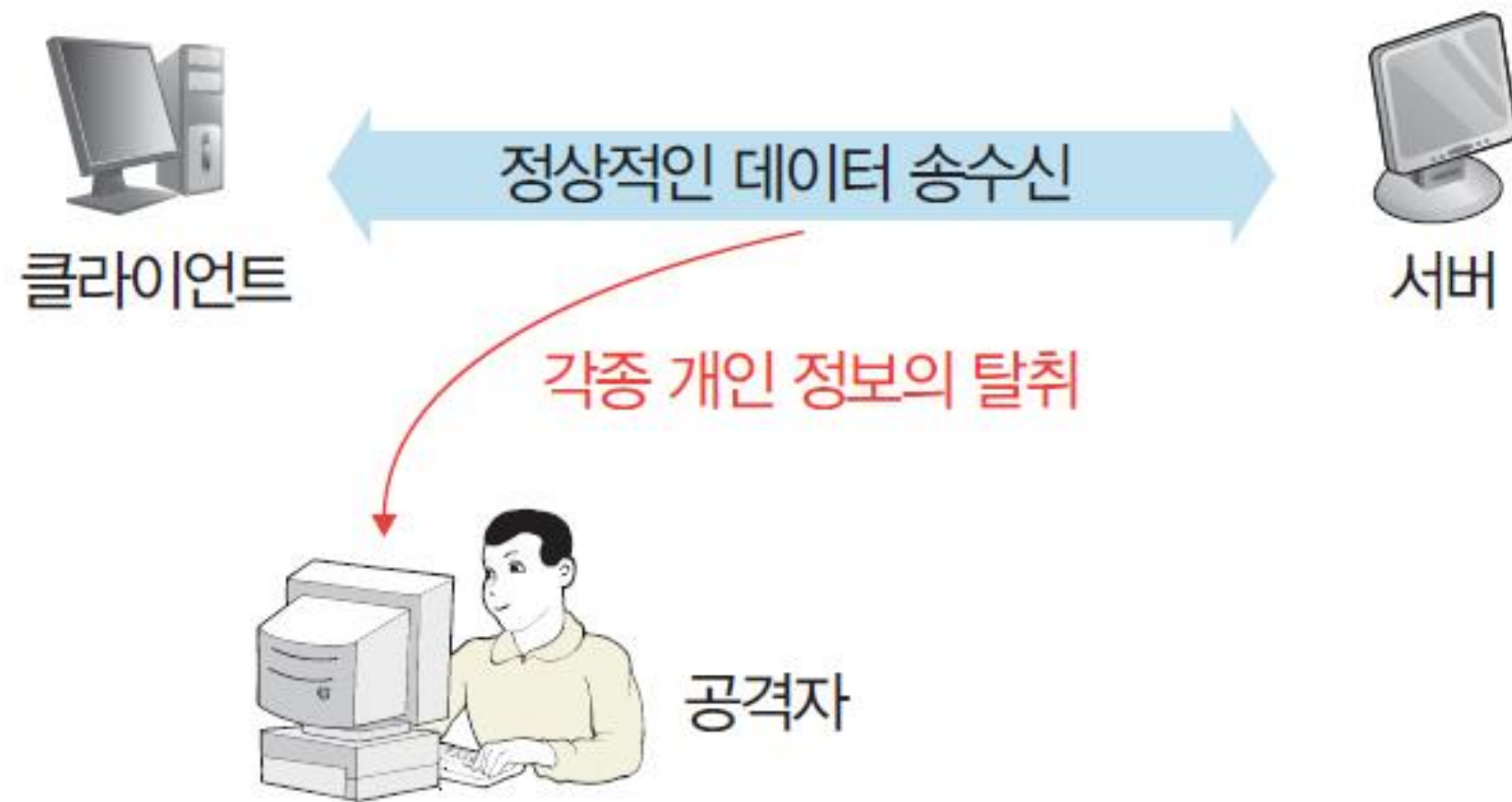


그림 9-12 스니핑의 동작

3. 해킹

6) XSS

◆ XSS

- 공격자가 게시판에 악성 스크립트가 포함된 글을 등록하면 사용자가 게시물을 열람하고, 그 순간 악성 스크립트가 실행되어 사용자의 정보가 공격자에게 전달됨

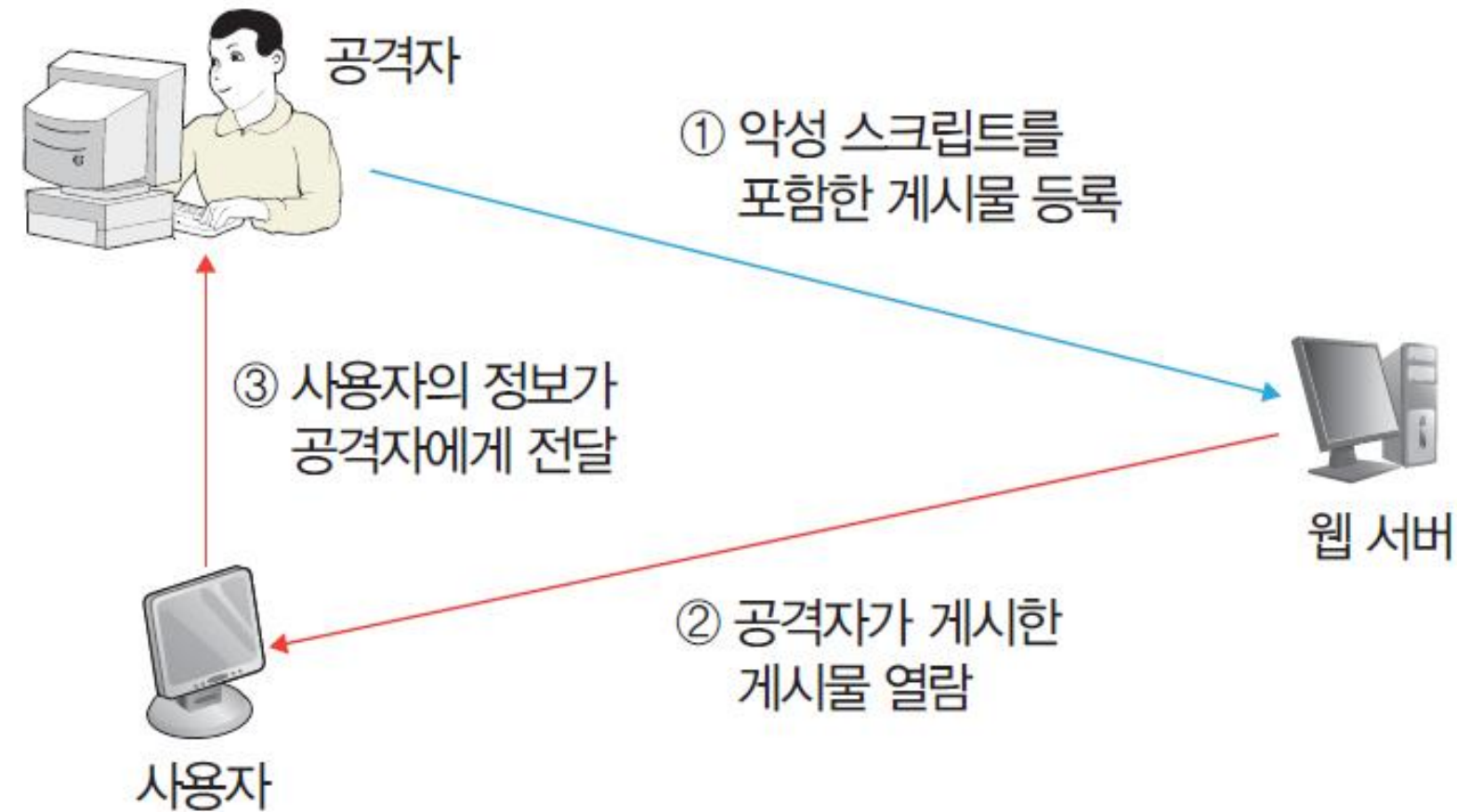


그림 9-13 XSS의 동작

3. 해킹

7) 피싱

◆ 피싱

- 공격자가 금융 기관 등으로 위장하여 개인 정보를 알아낸 뒤 이를 이용하는 사기 수법

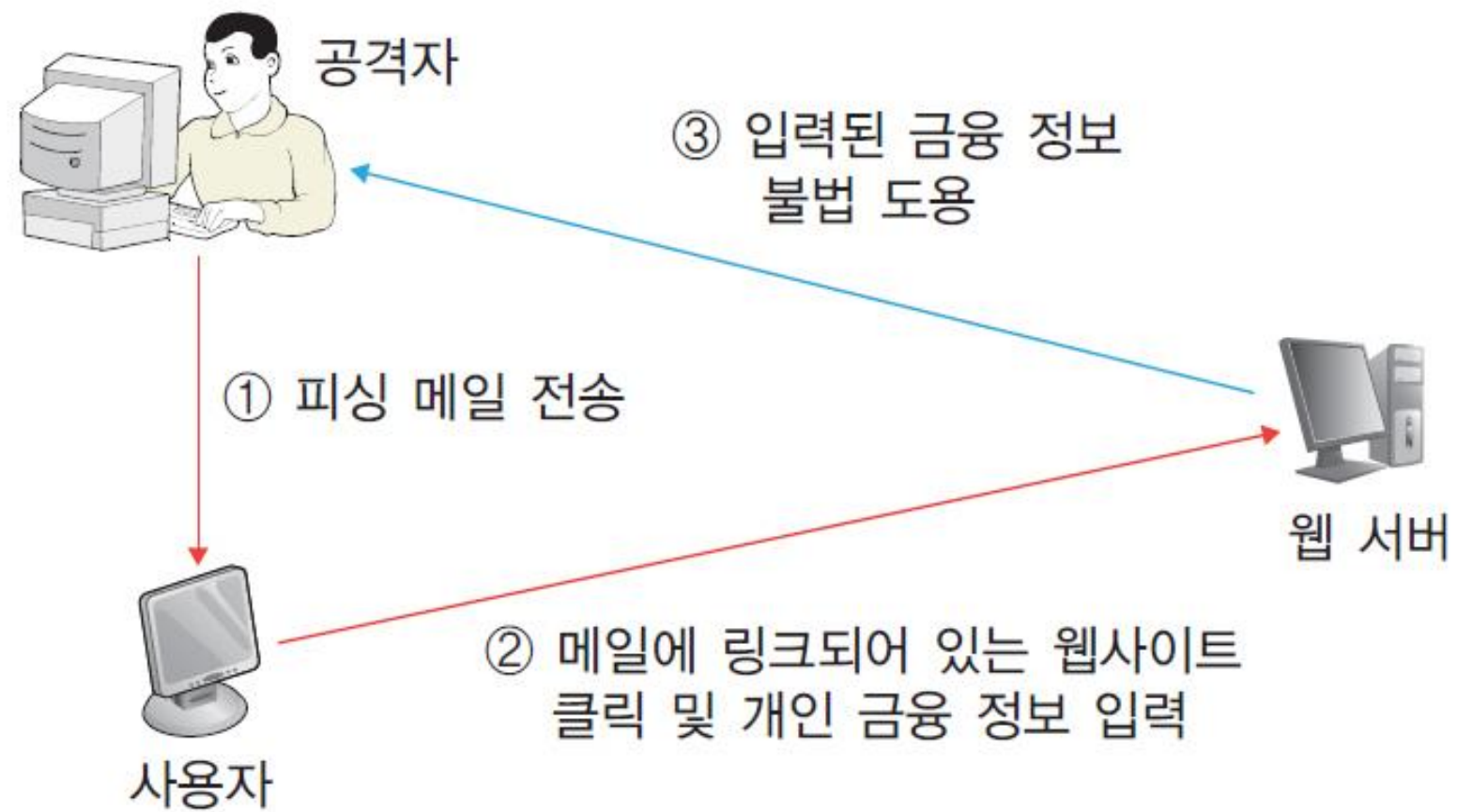


그림 9-14 피싱의 동작

3. 해킹

8) 모바일 디바이스 해킹

◆ 방식

- 특정 앱의 업데이트를 사칭해 악성 앱 링크를 문자 메시지로 보냄. 사용자가 앱 링크를 클릭하면 자신도 모르는 사이에 악성 앱이 설치됨
- 지하철, 커피숍 등에서 쓰이는 공용 와이파이를 이용해 타인의 스마트폰을 훔쳐봄
- QR코드로 악성코드를 유포

3. 해킹

8) 모바일 디바이스 해킹

◆ 피해

- 스마트폰에 저장된 주소록, 문자 메시지, 금융 정보 등의 개인 정보를 빼내 악용
- 스마트폰 카메라나 마이크를 의도적으로 작동시켜 사생활 엿듣
- 스마트폰의 GPS 위치 정보를 활용해 사용자의 위치 추적
- 스마트폰을 좀비 스마트폰으로 만들어 해당 지역 통신사 기지국을 공격하는 해킹 도구로 사용

3. 해킹

8) 모바일 디바이스 해킹

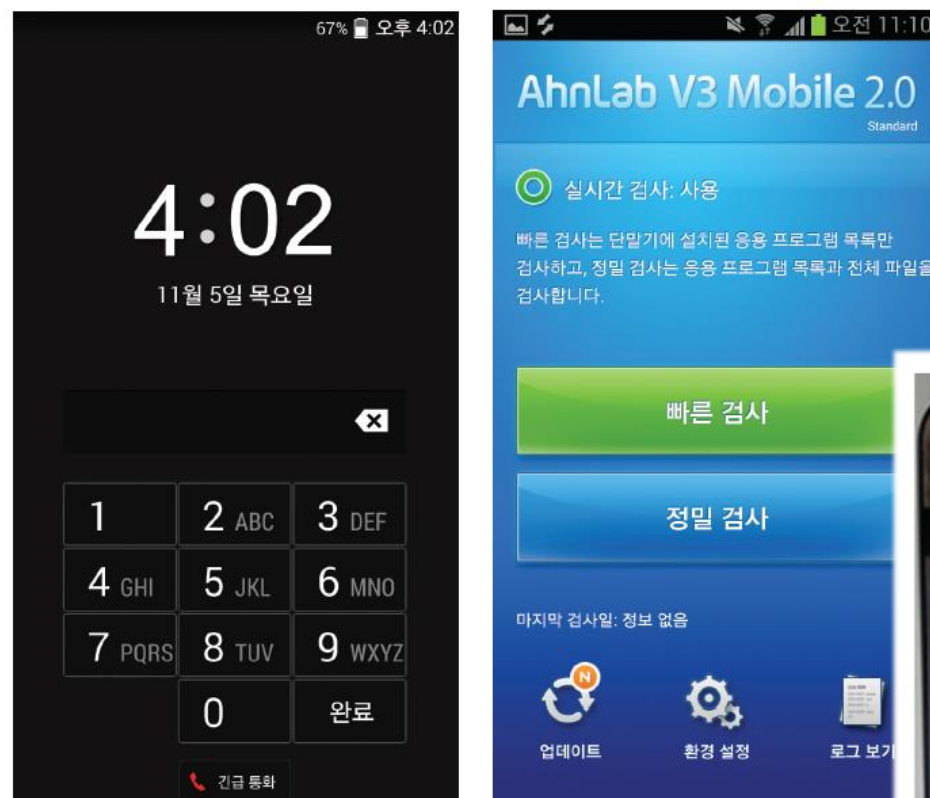
◆ 예방

- 스마트폰 비밀번호를 항상 설정해두기
- 블루투스 같은 무선 네트워크는 사용할 때만 켜기
- 중요한 정보는 스마트폰에 저장하지 않기
- 문자 메시지나 SNS로 수신된 의심스러운 URL은 클릭하지 말고, 알 수 없는 파일은 설치하지 않기
- 모바일 백신을 최신 버전으로 업데이트하고 실시간 감시 기능을 켜 놓기

3. 해킹

8) 모바일 디바이스 해킹

◆ 예방



(a) 비밀번호 설정

(b) 모바일 백신 설치

그림 9-15 모바일 디바이스 해킹 사전 예방 [01]



그림 9-16 한국전자통신연구원에서 개발한 미모 보안 칩 [02]



요약

◆ 정보보안

- 개념: 정보를 수집, 가공, 저장, 검색, 송수신하는 과정에서 발생하는 정보의 훼손, 변조, 유출 등을 방지하기 위한 관리적, 기술적 방법을 의미한다.

◆ 정보보안을 위협하는 공격형태

- 정보 가로막기, 정보 가로채기, 정보수정, 정보위조 등이 있다.

◆ 악성코드의 개념

- 컴퓨터에 악영향을 끼칠 수 있는 모든 소프트웨어를 총칭하며, 명령어 또는 악성 프로그램이라고도 한다.

◆ 해킹의 개념

- 다른 사람의 컴퓨터 또는 정보 시스템에 침입하여 정보를 빼내는 행위이다.

◆ 해킹의 종류

- 도스, 디도스, 스푸핑, 스니핑, XSS, 피싱, 모바일 디바이스 해킹